



תוכנית משימות מלאה לקראת Production

מסמך עבודה מאוחד המבוסס על בדיקות מוכנות, אבטחה וקבלת Staging

סטטוס נוכחי: מתאים לדמו מבוקר בלבד. לפני שימוש במידע רפואי אמיתי יש לסגור את שערי האבטחה, הזהות, התפעול והמשפט המפורטים במסמך.

31 באוגוסט 2026

1. מסקנה ניהולית

הבסיס הטכני של MyVet טוב: ה-build עובר, 440 בדיקות אוטומטיות עברו, מסד נקי הוקם בהצלחה, בידוד בסיסי בין מרפאות נבדק, תורים וביקורים נשמרים אטומית, ארבעת Buckets פרטיים ותרגיל שחזור טכני עבר.

החסם למכירה אינו חוסר בפיצ'רים. החסם הוא שילוב של שלוש פרצות הרשאה והרשמה מאומתות, Auth שאינו מוקשח מספיק, CI שאינו פעיל, ופערים תפעוליים ומשפטיים. יש להשלים את המשימות לפי הסדר הבא ולא לדלג ישירות לפריסת Production.

2. סדר הביצוע המומלץ

1. לסגור את שלושת חסמי ההרשאה F-022-F-024.
2. להריץ מחדש את בדיקות ההרשאה השליליות ב-Staging.
3. להקשיח Auth ולהשלים onboarding רב-מרפאתי.
4. להפעיל CI תקין על release candidate נקי.
5. לסגור ניטור, גיבוי, שחזור ותגובה לאירועים.
6. לסגור פרטיות, חוזים ומדיניות שמירת מידע.
7. להריץ E2E מלא ב-Staging ולבצע promotion rehearsal.
8. רק לאחר מעבר כל השערים - Pilot מוגבל עם מרפאה אחת.

3. P0 - חובה לפני כל שימוש בנתוני לקוחות אמיתיים

3.1 שלילת גישת Storage מעובד מושבת - F-022

מה לעשות

- לשנות את Policies של ה-storage הרפואי כך שבעלות טכנית על אובייקט לא תספיק לגישה.
- לחייב חברות צוות פעילה במרפאה גם כאשר `storage.objects.owner = auth.uid`.
- לבדוק SELECT, הורדה, Signed URL, עדכון ומחיקה לאחר השבתת העובד.

למה זה נדרש

בדיקת Staging הוכיחה שעובד עם `is_active=false` עדיין רואה קובץ רפואי שהעלה. עובד שעזב מרפאה אינו רשאי לשמור גישה למידע רפואי רק משום שהוא העלה את הקובץ.

תנאי קבלה

- עובד פעיל ומורשה רואה את הקובץ.
- לאחר השבתה, כל פעולות הגישה נחסמות מיד.
- וטרינר מורשה אחר באותה מרפאה ממשיך לעבוד כרגיל.
- מרפאה אחרת ובעלים לא מורשה אינם מקבלים `path`, `metadata` או Signed URL.

- בדיקת הרגרסיה נשמרת כחלק מחבילת הבדיקות.
- תלות: Migration ממוקד ל-Storage Policies; אין להחיל על Production לפני Staging ו-rollback review. מאמץ משוער: קטן-בינוני.

3.2 מניעת שיוך בעלים עמום בין מרפאות - F-023

מה לעשות

- לשנות את claim_owner_profile() כך שיבצע קישור רק כאשר קיימת התאמה יחידה ומוכחת.
- כאשר אותו אימייל קיים ביותר ממרפאה אחת, לא לשנות נתונים ולהחזיר שגיאה עסקית בטוחה.
- להעדיף הזמנה חד-פעמית או הקשר מרפאה מאומת בצד השרת על פני אימייל בלבד.

למה זה נדרש

בבדיקת Staging הפונקציה בחרה רשומת בעלים אחת מתוך שתי מרפאות עם אותו אימייל. זה עלול לשייך משתמש לתיק של מרפאה או בעל חיים שאינם שלו.

תנאי קבלה

- התאמה יחידה מקושרת בהצלחה.
- אפס התאמות או יותר מהתאמה אחת אינן משנות שום רשומה.
- אין אפשרות להשפיע על הבחירה באמצעות clinic_id מה-Frontend.
- הבדיקה מכסה שני tenants, duplicate email, retry ו-concurrency.
- תלות: Migration לפונקציה, סקירת grants ו-RLS, התאמת הודעת השגיאה ב-Frontend. מאמץ משוער: בינוני.

3.3 ביטול INSERT ישיר ל-owners והעברת הרשמה לשרת - F-024

מה לעשות

- להסיר מ-authenticated את היכולת ליצור רשומת owners ישירות דרך PostgreSQL.
- ליצור או להשתמש ב-RPC/Edge Function אטומי להרשמה.
- לאמת בצד השרת מרפאה, שדות חובה, אימייל, טלפון, הסכמות, כפילויות ושיוך Auth.
- לשמור על rollback במקרה שבו Auth נוצר אך רשומת הבעלים נכשלת.

למה זה נדרש

במסד Local נקי משתמש Auth חדש הצליח ליצור רשומת בעלים עם נתונים ריקים או לא תקינים, בלי לעבור דרך טופס ההרשמה. ולידציה בדפדפן אינה גבול אבטחה.

תנאי קבלה

- INSERT ישיר ל-owners נחסם.
- הרשמה תקינה דרך המסלול הרשמי מצליחה.
- נתונים חסרים, tenant לא חוקי, כפילויות ושינוי מזהים ידני נחסמים.
- אין רשומת Auth או owner יתומה לאחר כשל.

- תנאי השימוש והסכמה נשמרים באופן שניתן להוכיח.
- תלות: תכנון onboarding בסעיף 3.5. מאמץ משוער: בינוני.

3.4 הקשחת Supabase Auth - F-026/F-007

מה לעשות

- להפעיל leaked-password protection ב-Supabase.
- לקבוע מדיניות סיסמה, session lifetime, refresh, lockout/rate limit ושחזור חשבון.
- לחייב MFA לפחות למנהלי מרפאה ולמשתמשים בעלי הרשאות גבוהות.
- לבדוק password reset, revoke, disable, invite ושינוי תפקיד.

למה זה נדרש

Advisor של Production אישר שהגנת סיסמאות שדלפו כבוייה, ושאר מדיניות מחזור החיים של משתמשים טרם אומתה. מערכת רפואית אינה יכולה להסתפק בכך שההתחברות עובדת.

תנאי קבלה

- סיסמה ידועה כדולפת נחסמת.
- השבתת משתמש מבטלת גם session פעיל בהתאם למדיניות שנקבעה.
- MFA למנהל נבדק בפועל.
- recovery אינו מאפשר השתלטות או שינוי tenant.
- המדיניות והבעלות על חשבון Supabase מתועדות.
- תלות: הגדרות Dashboard ובדיקות Staging; אין צורך ב-rewrite. מאמץ משוער: קטן-בינוני.

3.5 Onboarding רב-מרפאתי ללא tenant קשיח - F-006

מה לעשות

- להסיר תלות ב-myvet-primary מתהליך ההרשמה.
- לבנות תהליך שרת ליצירת Clinic או להצטרפות באמצעות הזמנה מאומתת.
- להגדיר admin ראשון, הזמנת צוות, שעות פעילות ובעלות על מידע.
- להחליט אם משתמש יכול להשתייך לכמה מרפאות ומהו active clinic.

למה זה נדרש

Tenant קשיח מתאים לדמו של מרפאה אחת, אבל במוצר מסחרי הוא עלול לשייך לקוחות למרפאה שגויה ולשבור את הפרדת הנתונים.

תנאי קבלה

- שתי מרפאות חדשות נוצרות ונשארות מבודדות.
- הזמנה אינה ניתנת לשימוש חוזר או במרפאה אחרת.
- המשתמש אינו יכול לבחור clinic_id שרירותי מהדפדפן.

- קיימים revoke והעברת תפקיד בטוחים.
- תלות: סעיפים 3.2-3.4. מאמץ משוער: בינוני-גדול.

3.6 שער משפטי ופרטיות - F-003

מה לעשות

- להשלים DPA, DPIA, רשימת ספקי משנה והעברות מידע לחו"ל.
- לקבוע retention לכל סוג מידע: תיק רפואי, קבצים, תמלולים, AI logs, audit ו-backups.
- להגדיר מענה לעיון, תיקון, מחיקה, ייצוא ואירוע אבטחה.
- לאשר נוסחי פרטיות, הסכמה להקלטה/תמלול ותנאי שימוש עם גורם משפטי.

למה זה נדרש

המערכת מטפלת במידע מזהה, רפואי ותשלומים ומשתמשת בספקי ענן ו-AI. קוד תקין אינו מחליף בסיס חוקי, חוזים ומדיניות תפעולית.

תנאי קבלה

- המסמכים חתומים ומותאמים לזרימה בפועל.
 - כל ספק ומיקום עיבוד רשומים.
 - retention מיושם וניתן לבדיקה.
 - יש בעל תפקיד ותהליך מתועד לבקשות ולאירועים.
- תלות: החלטה עסקית ומשפטית; אין להציג זאת כיעוץ משפטי שהושלם על ידי בדיקת קוד. מאמץ משוער: גדול.

4. P1 - חובה לפני Pilot מסחרי ראשון

4.1 CI תקין ו-release candidate נקי - F-025/F-021

מה לעשות

- להכניס ל-Git את ה-workflow, deno.lock, המיגרציות והבדיקות המאושרות בלבד.
- למנוע הכנסת codex-auto-resume, פלטים מקומיים ו-credentials.
- לתקן את סדר ה-CI: build לפני סריקת bundle, או לפצל source scan ו-bundle scan.
- להוסיף gates ל-baseline, migrations, authorization, dependency audit ו-Staging smoke.
- להגן על master באמצעות CI ירוק וסקירה.

למה זה נדרש

ה-workflow הנוכחי אינו tracked וב-checkout נקי הוא צפוי להיכשל. בלי CI אין הוכחה שהגרסה שנבדקה היא הגרסה שתיפרס.

תנאי קבלה

- checkout חדש עובר התקנה, build, tests, type checks וסריקות ללא קבצים מקומיים.
- commit hash אחד מזוהה כ-release candidate.
- merge ל-master אינו אפשרי כאשר gate נכשל.

F-008 E2E למסעות הקריטיים - 4.2

מה לעשות

- לכסות התחברות צוות ובעלים, תור, ביקור, תיק רפואי, פורטל, Storage, תשלום דמו ו-VetBot.
- לכלול loading, validation, permissions, network failure, mobile ו-RTL.
- להריץ מול Staging עם משתמשים ונתונים סינתטיים.

למה זה נדרש

440 בדיקות היחידה והאינטגרציה נותנות כיסוי טוב לקוד, אך אינן מוכיחות שמשתמש יכול להשלים מסע מלא בדפדפן לאחר פריסה.

תנאי קבלה

- כל מסע מרכזי עובר מדפדפן ועד DB וחזרה.
- אין גישה בין tenants ואין טיטות בפורטל.
- כשל AI אינו משבית פעולה ידנית או DigitalCare.

F-004 4.3 ניטור, התראות ותגובה לאירועים - 4.3

מה לעשות

- להוסיף error tracking ל-Frontend ול-Edge Functions.
- להגדיר dashboards ו-alerts ל-migration, quota, Storage, DB connections, latency, Auth failures, 5xx ו-backup.
- להוסיף correlation/request ID ללא תוכן רפואי מלא.
- לכתוב incident runbook ולתרגל אירוע אחד.

למה זה נדרש

מערכת יכולה לעבור בדיקות ועדיין להיכשל אצל לקוח. בלי ניטור לא ניתן לזהות תקלה, להעריך היקף או להוכיח טיפול.

תנאי קבלה

- תקלה סינתטית יוצרת alert ומגיעה לבעל תפקיד.
- אפשר לעקוב אחר בקשה בין Frontend, Edge Function ו-DB בלי מידע רגיש בלוג.
- זמני תגובה ואחריות מוגדרים.

F-002 4.4 גיבוי, RPO/RTO ושחזור - 4.4

מה לעשות

- לאשר RPO/RTO עסקיים.
- להגדיר גיבוי אוטומטי נפרד ל-dump bytes של Storage object של DB אינו מגבה אותם.
- לתזמן restore drill תקופתי ולשמור ראיות.
- להגדיר מי מוסמך להפעיל שחזור וכיצד מאמתים שלמות.

למה זה נדרש

התרגיל הטכני עבר, אך הוא היה ידני וסינתטי. ללא מדיניות ואוטומציה אין התחייבות שניתן לשחזר מידע אמיתי בזמן מוסכם.

תנאי קבלה

- שחזור DB ו-Storage לסביבה מבודדת עומד ב-RPO/RTO.
- hashes וקישורי metadata תואמים.
- Production אינו מושפע מהתרגיל.

4.5 Promotion pipeline ויישור F-019 migrations

מה לעשות

- לפתור את סטטוס MIGRATIONS_FAILED של ענף Staging לפני promotion אוטומטי.
- לבדוק את שבע המיגרציות המאוחרות שאינן ב-Production לפי סדר, תאימות ו-rollback.
- לבצע rehearsal מלא על release candidate קפוא.
- להחיל על Production רק באישור מפורש ובחלון שינוי מתועד.

למה זה נדרש

Staging עבר קבלה ידנית, אבל Production רשום עם 25 migrations מול 32 בריפו. פריסת Frontend לפני הסכמה תואמת עלולה לשבור זרימות תורים, ביקורים והרשאות.

תנאי קבלה

- migration history תואם לגרסת הקוד.
- preflight, backup, rollback ו-post-deploy smoke מתועדים.
- אין שימוש ב-Production כדי לגלות בעיות בפעם הראשונה.

4.6 הרחבת מטריצת ההרשאות

מה לעשות

- להרחיב את בדיקות שתי המרפאות מעבר לקריאה בסיסית לכל פעולת כתיבה רגישה ולכל 43 הטבלאות הרלוונטיות.
- לבדוק שינוי תפקיד, משתמש מושבת, משתמש רב-מרפאתי, RPC, signed URLs, owner release, ו-Realtime.
- לסקור 18 אזהרות SECURITY DEFINER ו-multiple permissive policies לפי פונקציה/טבלה.

למה זה נדרש

דוח Staging מוכיח שהמודל הבסיסי עובד; דוח העומק מוכיח שתרחיש lifecycle שלא נכלל יכול לעקוף אותו. לכן PASS בסיסי אינו תחליף למטריצת פעולה מלאה.

תנאי קבלה

- deny מפורש לכל פעולה לא מורשית.
- כל RPC מאמת user, role, clinic והישות העסקית בצד השרת.
- אין חיפוש גלובלי ולאחריו סינון באפליקציה.

5. P1 טכני - הקשחה משלימה

משימה	למה צריך אותה	תנאי קבלה
לקבע search_path ב-public.set_updated_at	Advisor זיהה resolution mutable בפונקציה	Migration ממוקד, safe search_path, בדיקות trigger
Security headers ב-Vercel	אין CSP, frame-ancestors, Referrer/Permissions Policy	headers מאומתים ללא שבירת Supabase, SPA או Meet, fonts
audit trail תפעולי	ה-AI לבדו אינו מכסה קריאה/שינוי/מחיקה של מידע רפואי	אירועים מרכזיים מתועדים ללא תוכן רפואי מלא ואינם ניתנים לשינוי רגיל
retention scheduler	DigitalCare cleanup הוא best-effort	scheduler מנוטר, retry בטוח, מדדי הצלחה וכשל
rate limit מבוזר ל-AI	limiter בזיכרון ניתן לעקיפה במספר instances	מגבלה לפי משתמש/tenant בצד שרת משותף
malware/quarantine לקבצים	MIME וגודל אינם מזהים קובץ זדוני	סריקה, quarantine, חסימת הורדה עד אישור וניקוי בטוח
פורמט שגיאות אחיד	שגיאות הרשאה/רשת מוצגות לעיתים כבעיית זמינות	קוד שגיאה יציב, הודעה אנושית, request ID וללא stack/secret

6. P2 - איכות, נגישות וביצועים לפני הרחבת הלקוחות

משימה	למה צריך אותה
לתקן "lang="he", dir="rtl" ויותר האתר	נגישות, SEO וקוראי מסך; כרגע מסמך ה-HTML מוגדר באנגלית
להוסיף ErrorBoundary מערכתי	מסך בודד שקורס לא צריך להפיל את כל האפליקציה
להוסיף unsaved-changes guard	מניעת אובדן רשומה רפואית בזמן ניווט או רענון
להשלים focus trap, Escape והחזרת focus במודלים	נגישות מקלדת ושימוש תקין בדיאלוגים
לצמצם bundles מעל 500KB	זמן טעינה ויציבות במכשירים חלשים
לבטל תלות מיותרת בתמונות/Fonts חיצוניים	זמינות, ביצועים ופרטיות
לתקן את test:ai-data-integration	הבדיקה חסומה בגלל משתני Preview ולא נותנת כרגע gate אמיתי

משימה	למה צריך אותה
לבצע בדיקת נגישות מקצועית	בדיקות foundation אינן תחליף לסקירה מלאה לפי התקן הרלוונטי

7. AI - מה להשאיר כבוי ומה נדרש להפעלה

להשאיר כבוי כרגע

- RAG index ו-Q&A.
- OCR למסמכים ולחיסונים.
- סיכום ללקוח.
- הצעות מעקב.
- כל יכולת שלא עברה ספק אמיתי והרשאות Staging מלאות.

לפני הפעלה

- בדיקת ספק אמיתי, timeout, כשל ו-manual fallback.
 - ניטור x429/5, latency, tokens ועלות לפי tenant.
 - כיוול איכות ללא מידע אמיתי בשלב הראשון.
 - retention, DPA והעברת מידע מאושרים.
 - human approval לפני תוכן רפואי או פעולה עסקית.
- למה: ארכיטקטורת ה-Gateway וה-Adapters קיימת, אבל בדיקות Mock אינן מוכיחות איכות, פרטיות או זמינות של ספק חיצוני.

8. משימות עסקיות שחייבות להיסגר למוצר, גם אם הקוד תקין

משימה	למה צריך אותה
סליקה אמיתית ותהליך החזר/כשל	מנגנון התשלום הקיים הוא דמו ואינו billing מסחרי
SLA, תמיכה ותהליך escalation	לקוח צריך לדעת מי מטפל בתקלה ובאיזה זמן
onboarding וייבוא מידע אמין	import קיים אך חסרים dry-run, resume, rollback ודוח שגיאות ברמת שרת
בעלות על חשבונות cloud/domain	מניעת תלות באדם יחיד ואובדן גישה תפעולית
תמחור, חוזה ושימוש מותר	מוצר טכני אינו מוצר מסחרי ללא מסגרת שירות והתחייבויות

9. מה לא לעשות עכשיו

- לא לבצע rewrite, microservices או Kubernetes.
- לא למחוק 118 אינדקסים או לאחד Policies רק משום שה-Advisor סימן אותם; יש למדוד ולסקור אחד-אחד.

- לא להפעיל FORCE RLS אוטומטית על כל טבלה ללא בדיקת maintenance ו-service paths.
- לא להפעיל AI מתקדם או RAG על מידע אמיתי לפני ספק, הרשאות ומשפט.
- לא לבצע promotion או להחיל את שבע המיגרציות על Production ללא release candidate, גיבוי ואישור מפורש.

10. אבני דרך והחלטות Go/No-Go

Gate A - Security Fixes

נדרש PASS ל-F-022, F-023 ו-F-024 ב-Staging.

אם אחד נכשל: NO-GO.

Gate B - Identity and Tenant

נדרש PASS ל-MFA, Auth hardening, למנהלים, invite/revoke, onboarding ובידוד שתי מרפאות.

אם אחד נכשל: NO-GO.

Gate C - Release and Operations

נדרש CI ירוק על commit קפוא, E2E קריטי, ניטור, backup/restore ו-promotion rehearsal.

אם אחד מהשערים התפעוליים הקריטיים חסר: NO-GO ללקוח אמיתי.

Gate D - Legal and Pilot Approval

נדרשים מסמכי פרטיות/חוזים מאושרים, retention, בעל תפקיד ותוכנית תמיכה. לאחר מעבר Gate A-D ניתן להתחיל Pilot מוגבל עם מרפאה אחת, נתונים מינימליים ותמיכה צמודה.

11. המשימה הבאה המומלצת

לבצע יחד חבילת תיקון אחת ומבודדת לשלושת החסמים F-022-F-024:

1. לתקן Storage revoke.
 2. להקשיח claim_owner_profile().
 3. להעביר יצירת owners למסלול שרת בלבד.
 4. ליצור migrations נפרדות והפיכות.
 5. להריץ Local clean-room, בדיקות RLS שליליות ו-Staging acceptance.
 6. לעצור לפני Production ולהציג diff, SQL, תוצאות ו-rollback לאישור.
- זו החבילה בעלת הערך הגבוה ביותר כרגע, משום שהיא סוגרת סיכוני חשיפת מידע ושיוך שגוי לפני כל שיפור תפעולי או עיצובי אחר.